

BuildWeek_III_Wireshark_HTTP/S

Consegna

Obiettivi

- Parte 1 Catturare e visualizzare il traffico HTTP
- Parte 2 Catturare e visualizzare il traffico HTTPS

Contesto / Scenario

HyperText Transfer Protocol (HTTP) è un protocollo a livello di applicazione che presenta i dati tramite un browser web. Con HTTP, non c'è salvaguardia per i dati scambiati tra due dispositivi comunicanti.

Con HTTPS, viene utilizzata la crittografia tramite un algoritmo matematico. Questo algoritmo nasconde il vero significato dei dati scambiati. Questo viene fatto attraverso l'uso di certificati che possono essere visualizzati più avanti in questo laboratorio. Indipendentemente da HTTP o HTTPS, si raccomanda di scambiare dati solo con siti web di cui ci si fida. Solo perché un sito usa HTTPS non significa che sia un sito affidabile. Gli attori malevoli usano comunemente HTTPS per nascondere le loro attività.

In questo laboratorio, esplorerai e catturerai il traffico HTTP e HTTPS usando Wireshark.

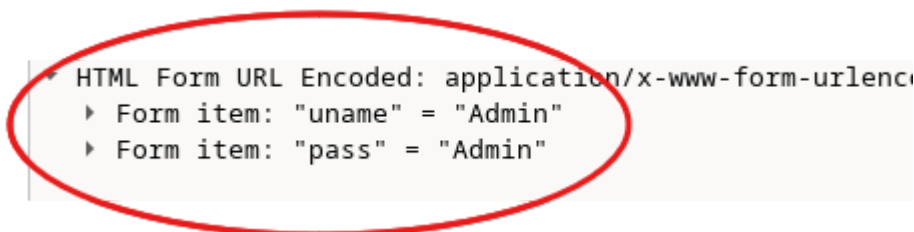
Risorse Richieste

- Kali Linux
- Connessione Internet

Svolgimento

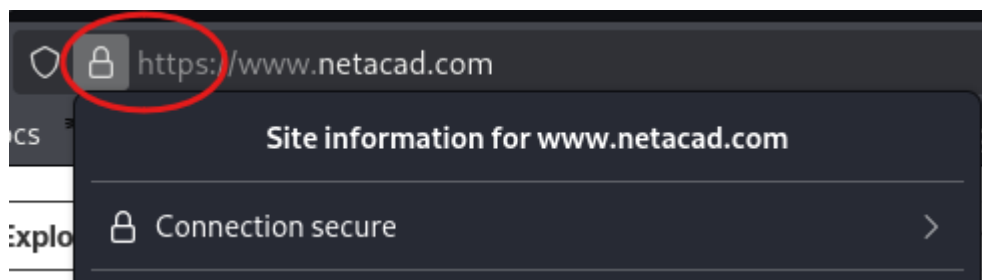
Quali due informazioni vengono visualizzate?

Le informazioni visualizzate all'interno della sezione HTML del pacchetto POST sono le credenziali inserite per il login che, venendo trasmesse in HTTP, appaiono in chiaro:



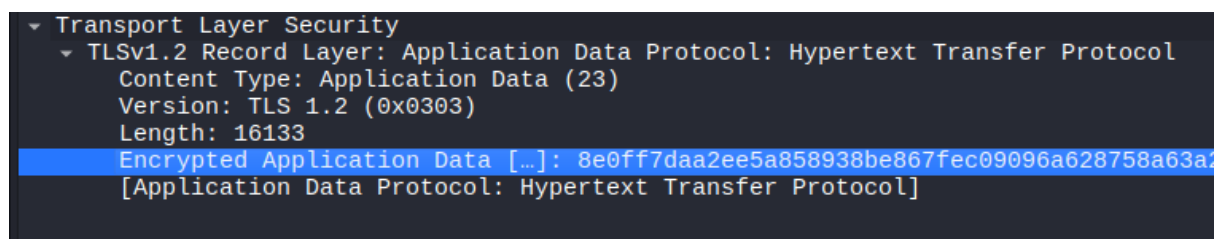
Cosa noti riguardo all'URL del sito web?

Si nota che il sito web utilizza un protocollo HTTPS che sfrutta TLS (Transport Layer Security) per garantire confidenzialità, integrità e autenticazione delle comunicazioni web tra client e server.



Cosa ha sostituito la sezione HTTP che era nel file di cattura precedente?

La sezione HTTP precedentemente osservata è stata sostituita con una sezione TLS dove il traffico non risulta più leggibile in chiaro in quanto criptato.



I dati dell'applicazione sono in formato plaintext o leggibile?

Come affermato poco fa, il testo non appare in formato plaintext in quanto lo scambio di informazioni avviene tramite TLS che encripta ogni comunicazione.

Domande di Riflessione

1. Quali sono i vantaggi dell'uso di HTTPS invece di HTTP?

HTTPS fornisce **confidenzialità**: i dati sono cifrati in transito, quindi lo sniffing non ne può rivelare il contenuto, **integrità**: i record TLS includono meccanismi che impediscono modifiche silenti dei messaggi, e **autenticazione** del server tramite certificati X.509 per ridurre il rischio di attacchi man-in-the-middle.

Grazie a TLS si possono usare funzionalità moderne e più performanti (HTTP/2, multiplexing, push) e abilitare cookie sicuri, HSTS e same-site, migliorando privacy e sicurezza applicativa. Infine, molti browser e motori di ricerca preferiscono siti HTTPS (migliore UX e compliance).

2. Tutti i siti web che usano HTTPS sono considerati affidabili?

Il protocollo HTTPS ci rassicura soltanto sul fatto che la **connessione** tra client server è cifrata e che il certificato è stato firmato da una CA riconosciuta. Non viene garantito però che il contenuto o l'intento del sito siano legittimi: un sito di phishing può avere un certificato valido.

Certificati scaduti, CA compromesse, configurazioni TLS deboli o domini fuorvianti (typosquatting) possono ancora esporre l'utente a rischio. Quindi HTTPS è necessario ma non sufficiente per fidarsi di un sitoweb; occorrono quindi approfondimenti sul dominio, reputazione, contenuti e pratiche server-side (es. protezione XSS/SQLi, header di sicurezza).

Conclusioni

L'esercitazione mostra chiaramente la differenza fondamentale tra HTTP e HTTPS. Con **HTTP** il contenuto delle richieste (es. credenziali POST) è **visibile in chiaro** in una cattura Wireshark, quindi facilmente **intercettabile e sfruttabile**. Con **HTTPS** il payload è **cifrato tramite TLS**: nella cattura i pacchetti mostrano una sezione TLS **non leggibile**, proteggendo confidenzialità e integrità durante il transito.

HTTPS protegge il canale ma **non garantisce che il sito sia legittimo** né che l'applicazione sia sicura; bisogna adottare anche **controlli applicativi** (validazione input, prepared statements, header di sicurezza) e una configurazione TLS corretta (certificati affidabili, cipher moderni, HSTS).